

PREPARED IN RESPONSE TO AI-SPM MVP PROJECT REQUIREMENTS

AI Security Posture Management Platform

Enterprise AI security solution with endpoint agent and central gateway — intercepting every AI interaction from ChatGPT, Claude, and other providers before data leaves the organization.

Endpoint Agent

AI Gateway

PII Protection

Threat Detection

Policy Engine

Admin Dashboard

PREPARED FOR

Client Organization

PREPARED BY

Development Team

DURATION

12 Weeks

VERSION

2.0 — June 2026

1. Executive Summary

Our proposed enterprise response to the AI-SPM MVP requirements.

Employees use AI tools such as ChatGPT and Claude directly in their browsers — creating uncontrolled pathways for data leakage and policy violations. We propose a **dual-component platform**: a lightweight **endpoint agent** installed on each workstation that intercepts AI traffic, and a central **AI security gateway** on the company server that inspects every prompt and response before it reaches any external LLM provider.

Our Approach: Users continue using ChatGPT, Claude, and Gemini as they do today. The endpoint agent runs silently in the background, routing all AI traffic through our security gateway. The gateway applies PII masking, policy enforcement, and threat detection — then forwards only safe, sanitized prompts to the AI provider. Security administrators manage the platform via a React-based admin dashboard.



2. Understanding of Requirements

How we address each challenge identified in the project brief.

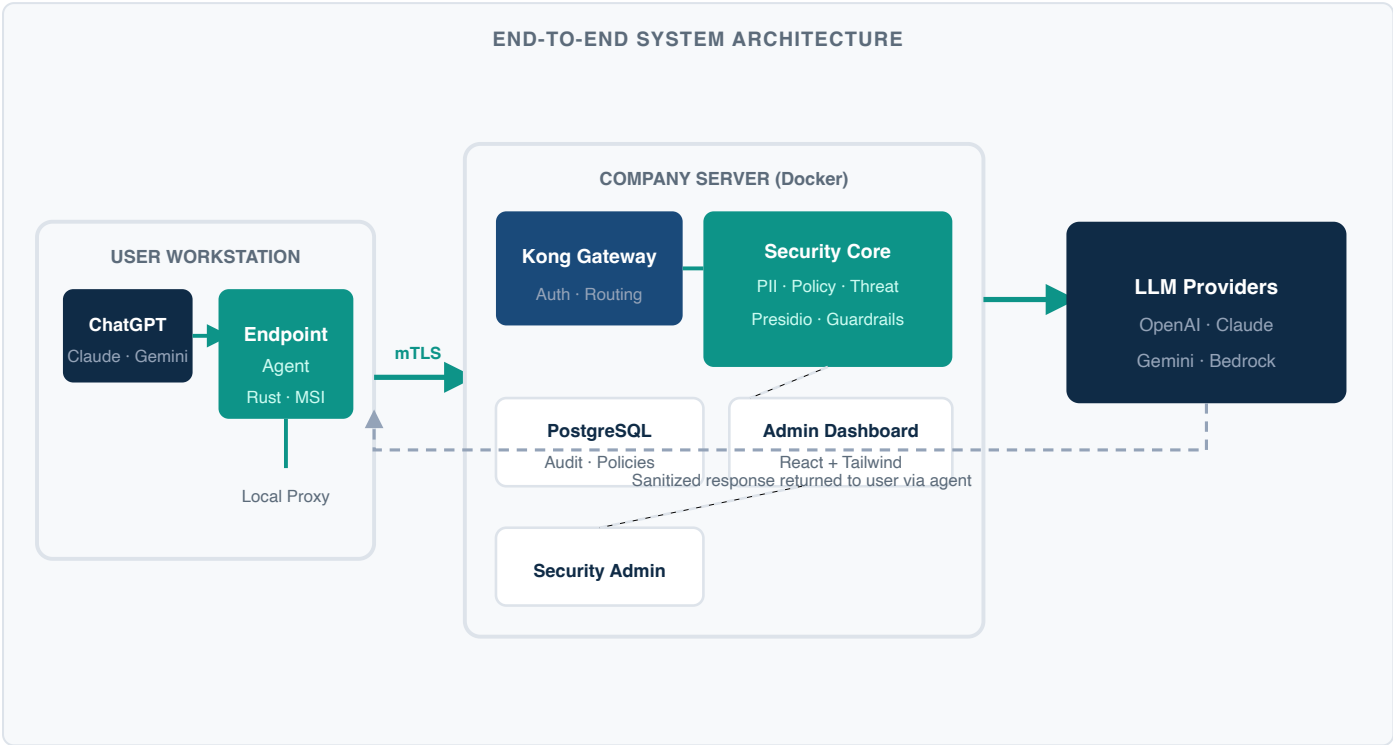
Challenge	Business Risk	Our Response
Employees use ChatGPT/Claude directly	Security bypass, shadow AI	Endpoint agent intercepts all AI traffic on the user's PC
Sensitive data pasted into AI prompts	Data breach, regulatory fines	Gateway masks PII (CNIC, SSN, cards) via Presidio before LLM call
No control over AI model access	Policy violations, cost overruns	Central gateway enforces role-based model permissions
AI-specific attacks (injection, jailbreak)	Security incidents	Guardrails AI threat scanning on every interaction
No visibility into AI usage	Failed audits, compliance gaps	Immutable audit logs and admin monitoring dashboard

Project Scope

IN SCOPE — 12 WEEK MVP - Windows Endpoint Agent (MSI installer) - AI Security Gateway with OpenAI integration - PII detection and masking engine - Policy engine with RBAC - AI threat detection module - Admin dashboard and audit logs - Docker deployment package - Technical documentation	DEFERRED — FUTURE PHASE - macOS / Linux endpoint agents - Kafka / Flink streaming pipeline - Neo4j graph database - Advanced Garak / ODIN automation - HA Kubernetes deployment
---	--

3. Solution Architecture

Agent + Gateway dual-component design for complete AI traffic control.



Component Responsibilities

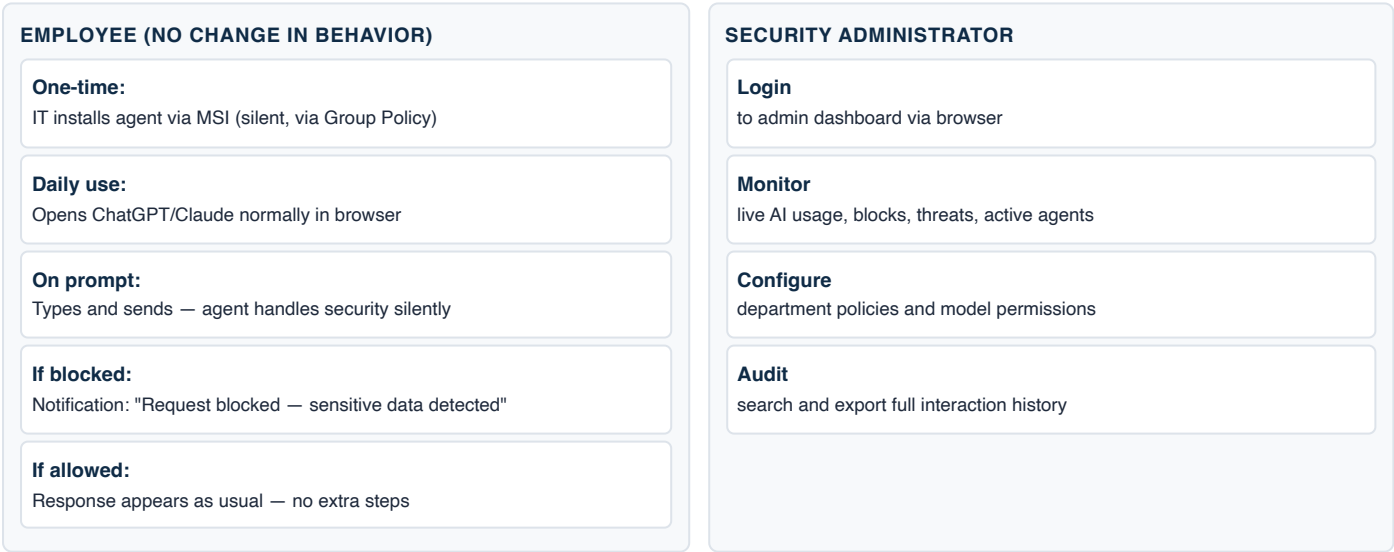
Component	Location	Responsibility
Endpoint Agent	User's Windows PC	Intercept AI traffic from browser; forward to gateway; deliver responses to user; auto-start on boot
AI Gateway (Kong)	Company server	Authenticate agent; route requests; rate limiting; TLS termination
Security Core (FastAPI)	Company server	PII scan, policy check, threat detection, LLM proxy, audit logging
PostgreSQL	Company server	Store audit logs, policies, user roles, agent registrations
Admin Dashboard	Company server (web)	Monitor usage, configure policies, view threats, manage agent fleet

4. Application Flow

What happens when an employee uses ChatGPT or Claude with the agent installed.



User Experience



PII Masking Example

Stage	Content
User types	"My CNIC is 35202-1234567-9 — summarize this report"
Agent sends to gateway	Original prompt (over mTLS)
Gateway sends to ChatGPT	"My CNIC is ***** — summarize this report"
Audit log	User, timestamp, CNIC masked, action: allowed — original never stored

5. Endpoint Agent — Design & Technology

Enterprise-grade Windows agent for transparent AI traffic interception.

Agent Architecture

Sub-Component	Function
Local Proxy Engine	Intercepts HTTP/HTTPS traffic to AI provider domains (chat.openai.com, claude.ai, api.anthropic.com, etc.)
Gateway Connector	Maintains persistent mTLS connection to AI-SPM gateway; forwards intercepted prompts and responses
Windows Service	Runs as a background system service — starts on boot, cannot be closed by user
System Tray UI (Tauri)	Minimal status icon showing connection state: Protected / Disconnected / Blocked
Auto-Updater	Checks gateway for agent updates; silent patch deployment via MSI
Heartbeat Monitor	Sends health signal to gateway every 60s; offline agents flagged in admin dashboard

Agent Technology Stack

Core Engine	Rust	High-performance proxy and network layer; memory-safe with no runtime garbage collection pauses
System Tray	Tauri 2	Lightweight native UI shell (~5 MB) using system WebView — far smaller than Electron (~150 MB)
Windows Service	windows-service crate	Registers as a Windows Service for always-on background operation and auto-start on boot
Installer	WiX Toolset (MSI)	Enterprise-standard MSI package; supports silent install and Group Policy (GPO) mass deployment
Agent ↔ Gateway	mTLS (rustls)	Mutual TLS authentication — only registered agents can connect to the gateway
Local Proxy	hyper + tokio	Async HTTP proxy intercepting AI provider domains; sub-millisecond local overhead

Why Rust for the Endpoint Agent

ENTERPRISE REQUIREMENTS MET

- **Small binary** — ~8–15 MB installer vs 150 MB+ for Electron
- **Low resource use** — <30 MB RAM idle; no impact on user productivity
- **Memory safe** — no buffer overflows; critical for security software
- **Tamper resistant** — compiled binary harder to modify than interpreted apps
- **Always-on reliable** — no GC pauses; stable Windows Service operation

WHY NOT ALTERNATIVES

- **Electron** — Too heavy (~150 MB); high RAM; not suitable for always-on agent
- **C# / .NET** — Viable but larger runtime dependency; Rust preferred for proxy performance
- **Python** — Requires runtime install; not suitable for enterprise MSI deployment
- **Go** — Good alternative; Rust chosen for stronger memory safety guarantees

Deployment & Distribution

IT administrators distribute the agent via **MSI silent install** through Active Directory Group Policy. No user interaction required. Agent auto-registers with the gateway on first launch using a pre-configured organization token.

6. Platform Modules & Server Technology

Gateway-side modules and server technology stack with rationale.

Module	Implementation	Technology
AI Gateway	Kong routes agent traffic; FastAPI proxies to LLM APIs; all requests logged	Kong, FastAPI, OpenAI API
Data Protection	Presidio pipeline on every inbound prompt; CNIC/SSN/card masking; custom recognizers	Microsoft Presidio, spaCy
Threat Detection	Guardrails AI validators on inbound prompts and outbound responses	Guardrails AI
Policy Management	JSON policy rules in PostgreSQL; RBAC per department; evaluated on every request	FastAPI, PostgreSQL
Dashboard	React SPA — usage metrics, threat feed, agent fleet status, audit log viewer	React, TypeScript, Tailwind

Server Technology Stack

API Gateway	Kong	Industry-standard; plugin ecosystem for auth, rate limiting, and logging at the edge
Backend	Python (FastAPI)	Native Presidio and Guardrails AI integration; async high-throughput request processing
Database	PostgreSQL 16	ACID-compliant audit logs, policy store, agent registry, full-text search
PII Engine	Microsoft Presidio	Enterprise NER + regex; extensible custom recognizers for CNIC and local formats
Threat Engine	Guardrails AI	Real-time prompt injection, jailbreak, and content policy validation
Dashboard	React + Tailwind	Type-safe admin UI for monitoring, policy config, and agent fleet management
Deployment	Docker Compose	Single-command server deployment; upgrade path to Kubernetes (deferred)

Security Design

COMMUNICATION SECURITY - TLS 1.3 between agent and gateway (mTLS) - TLS between gateway and LLM providers - Agent binary code-signed (Authenticode) - Organization token for agent registration	DATA & AUDIT SECURITY - PII masked before leaving the organization - Original sensitive values never stored - Append-only audit log in PostgreSQL - RBAC for all admin dashboard functions
--	---

7. Implementation Plan

12-week phased delivery — agent and gateway developed in parallel.

Phase	Weeks	Gateway Deliverables	Agent Deliverables
Phase 1	1–3	Kong setup, FastAPI core, OpenAI proxy, auth, logging	Agent architecture, local proxy prototype, gateway registration
Phase 2	4–6	Presidio PII pipeline, masking engine, secure forwarding	Windows Service, mTLS connector, ChatGPT/Claude domain interception
Phase 3	7–9	RBAC policy engine, React dashboard, audit log viewer	MSI installer, Tauri tray UI, GPO deployment guide, agent fleet panel
Phase 4	10–12	Guardrails threat detection, Docker package, documentation	Security testing, code signing, UAT, go-live support

Phase Milestones & Demos

Wk 3	Gateway Demo — End-to-end proxy: prompt → gateway → OpenAI → logged response. Agent prototype intercepting test traffic.
Wk 6	Agent + Security Demo — Agent installed on test PC; ChatGPT prompt intercepted, CNIC masked at gateway, sanitized prompt forwarded to OpenAI.
Wk 9	Policy + Fleet Demo — Admin dashboard live. Department policies enforced. Agent fleet visible (online/offline). MSI silent install demonstrated.
Wk 12	Go-Live — Full platform deployed. Threat detection active. Agent MSI distributed. UAT signed off. Documentation delivered.

Quality Assurance

Test Area	When	Method
Agent interception	Phase 2–4	Verify ChatGPT and Claude traffic captured on Windows 10/11
PII masking accuracy	Phase 2–4	Test CNIC, SSN, credit card, email detection and masking rates
Policy enforcement	Phase 3–4	Validate RBAC rules block/allow per department role
Threat detection	Phase 4	Simulated prompt injection and jailbreak attempts
Agent deployment	Phase 4	Silent MSI install via GPO; agent auto-registration verified
Performance	Phase 4	Total latency overhead target <300ms (p95) including agent + gateway

8. Deliverables & Acceptance Criteria

Complete list of outputs at project completion.

#	Deliverable	Description
1	Windows Endpoint Agent (MSI)	Rust-based agent; local proxy; Windows Service; Tauri tray UI; code-signed MSI installer
2	AI Security Gateway	Kong + FastAPI proxy; OpenAI integration; agent authentication; request logging
3	PII Masking Engine	Presidio-based detection and masking of CNIC, SSN, cards, emails, phones
4	Policy & RBAC Engine	Department-level rules enforced on every AI interaction
5	Threat Detection Module	Guardrails AI — injection, jailbreak, malicious content detection
6	Audit Log System	Complete searchable record of all AI interactions and agent events
7	Admin Dashboard	Usage metrics, threat feed, agent fleet panel, security score, policy UI
8	Docker Deployment Package	Containerized gateway stack — deployable in under 30 minutes
9	Documentation	Architecture doc, API reference, admin guide, agent GPO deployment guide

Go-Live Acceptance Criteria

- Agent MSI installs silently on Windows 10/11
 - ChatGPT and Claude traffic intercepted by agent
 - PII (CNIC, SSN, credit card) masked before LLM call
 - Prompt injection attempts detected and blocked
 - RBAC policies enforced per department
- All interactions logged in searchable audit trail
 - Agent fleet visible in admin dashboard
 - Gateway deployed via Docker Compose
 - Total latency overhead <300ms (p95)
 - Documentation complete and reviewed by client

9. Assumptions, Dependencies & Next Steps

CLIENT DEPENDENCIES

- Linux server (8 vCPU, 16 GB RAM) for gateway deployment
- Windows 10/11 test machines for agent development and UAT
- Active Directory access for MSI/GPO deployment testing
- OpenAI API key for integration testing
- Sample CNIC and data patterns for custom PII rules
- Dedicated contact for weekly sprint reviews

OUR COMMITMENTS

- Deliver all 9 deliverables within 12 weeks
- Weekly progress demos at each phase milestone
- Agent code-signed with Authenticode certificate
- Transparent communication throughout engagement
- UAT support and go-live assistance in Week 12

Next Steps

Step	Action	Timeline
1	Proposal review and approval by client	Week 0
2	Kick-off meeting — environment setup, access provisioning	Week 0
3	Phase 1 begins — gateway and agent development in parallel	Week 1
4	First demo — gateway proxy and agent prototype	Week 3

Summary: We will deliver a complete AI-SPM platform — Windows endpoint agent and central security gateway — within 12 weeks. Employees continue using ChatGPT and Claude normally; all AI traffic is secured, logged, and governed transparently. We are ready to begin upon approval.